A Risk Aware Framework for Trustworthy Generative AI

Samarth Pagaria
Department of Computer Engineering
Vidyalankar Institute of Technology
Mumbai, India
pagariasamarth@gmail.com

***Abstract*—Generative artificial intelligence has transitioned from proof of concept prototypes to systems that generate text, code, images, and decisions that affect users. This gap between model capability and responsible deployment leaves generative AI systems capable of producing useful and fluent outputs while also exhibiting hallucination, bias, privacy leakage, insecure behavior, and excessive user dependence. This paper proposes a practical risk aware framework for responsible generative AI that combines lifecycle governance, prompt and data controls, retrieval grounding, output validation, human oversight, and continuous evaluation. The framework maps technical controls to four operational stages: pre deployment assessment, controlled generation, post generation verification, and continuous monitoring. A multidimensional evaluation matrix is proposed using factuality, fairness, privacy, security, explainability, robustness, and human oversight as core dimensions. The framework complements established guidance from NIST, UNESCO, and OWASP rather than replacing domain specific governance. A conceptual analysis shows how individual controls address different classes of generative AI risk and how defense in depth reduces the likelihood that a single model failure becomes a harmful system outcome. The paper concludes that responsible generative AI should be treated as a systems engineering problem rather than only a model training problem.**

***Index Terms*—responsible AI, generative AI, large language models, AI safety, fairness, explainability, privacy, prompt injection, human oversight**

I. Introduction

Generative artificial intelligence systems based on large language models can generate fluent responses across a wide range of tasks. Their ability to summarize documents, answer questions, generate software, assist decision making, and interact in natural language has made them desirable for education, healthcare, finance, public services, and enterprise applications. However, the same flexibility that makes them attractive also makes them difficult to control. An LLM does not guarantee that a fluent response is factually correct, unbiased, private, or secure for the context in which it is used.

Hallucination is one of the most visible reliability issues. Research surveys describe hallucination as generation of plausible but nonfactual content and identify challenges in both detection and mitigation. In a deployed application, a hallucinated statement can become more severe when users accept it as authoritative information. Security introduces another layer of risk. The OWASP Top 10 for LLM Applications identifies prompt injection, sensitive information disclosure, supply chain weaknesses, data poisoning, and insecure output handling as important risks for LLM applications. These risks show that the model itself cannot be the complete security boundary.

Responsible AI therefore requires a broader approach. UNESCO emphasizes human rights and dignity, transparency, fairness, and human oversight while NIST provides a lifecycle oriented AI Risk Management Framework and a dedicated profile for generative AI. These principles are valuable, but engineering teams still need a practical mechanism for translating them into application level controls.

This paper proposes a risk aware framework for responsible generative AI applications. The main contribution is a layered architecture that links risk identification to concrete technical and organizational controls. Instead of assuming that one model level technique solves all risks, the framework uses defense in depth and combines input controls, trusted knowledge sources, model policies, output verification, security controls, human review, audit logging, and continuous evaluation.

The remainder of this paper is organized as follows. Section II reviews the foundations and related work. Section III presents the proposed framework. Section IV describes the risk assessment methodology. Section V presents a conceptual evaluation matrix. Section VI discusses an implementation architecture. Section VII discusses implications and trade offs. Section VIII identifies limitations and future research directions. Section IX concludes the paper.

II. Background and Related Work

A. Generative AI and Large Language Models

Large language models learn statistical relationships from large collections of text and generate output by predicting likely token sequences conditioned on an input context. This mechanism explains both their flexibility and their limitations. A model can produce a response that is linguistically coherent without possessing a guaranteed representation of truth. Consequently, factuality must be evaluated at the application level rather than through fluency.

B. Hallucination and Factual Reliability

Hallucination can occur when a model generates information that is unsupported by its training data, context,

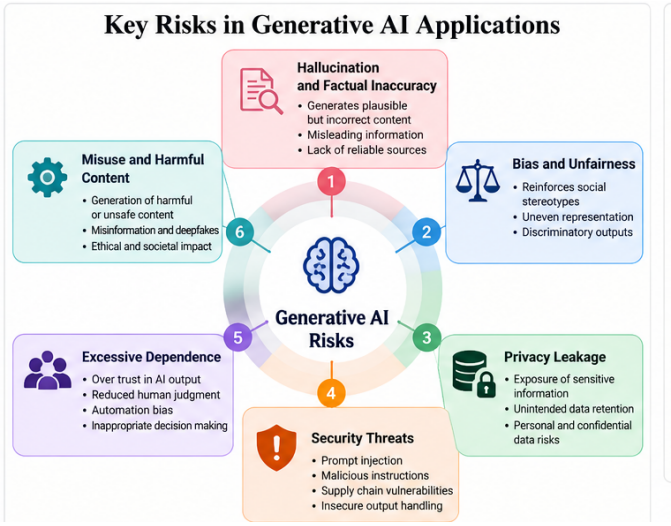


Fig. 1. Key risks associated with generative AI applications.

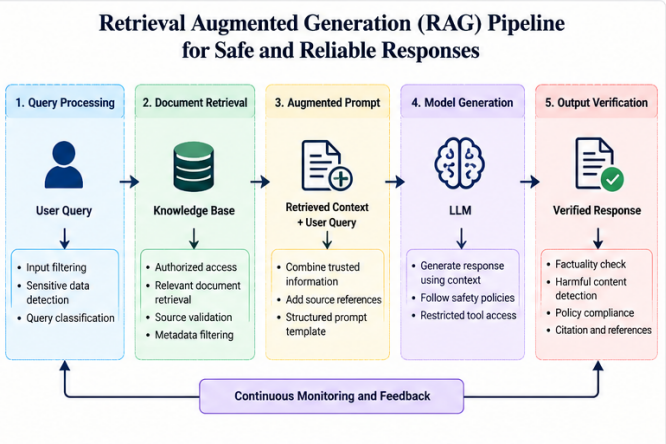


Fig. 2. Retrieval augmented generation pipeline with safety and verification mechanisms.

or retrieved evidence. Survey research categorizes hallucinations and examines causes, detection approaches, and mitigation strategies. Retrieval augmented generation can improve grounding by providing external evidence to the model, but retrieval does not automatically guarantee correctness. Retrieved documents can be incomplete, outdated, irrelevant, malicious, or incorrectly interpreted. A responsible architecture should therefore combine retrieval with source validation, citation, confidence handling, and output verification.

C. Fairness and Bias

Generative systems can reproduce social stereotypes and uneven representations present in training data. Bias can appear in the model, the prompt, the retrieved context, or the way an output is used. This means fairness cannot be reduced to one benchmark score. Evaluation should consider multiple demographic groups, task contexts, and failure modes. Responsible deployment should also include a process for reporting and reviewing harmful outputs.

D. Privacy

Generative AI applications may process personal, confidential, or proprietary information through prompts, retrieved documents, logs, or model training pipelines. Privacy protection therefore has to cover the complete information flow. Sensitive information should be minimized before it reaches the model, access to knowledge sources should be controlled, logs should be protected, and retention should be limited according to the application's requirements.

E. Security of LLM Applications

LLM applications introduce security problems that are different from those of traditional software systems. Prompt injection can manipulate model behavior through crafted input or untrusted retrieved content. Insecure output handling can become dangerous when model generated content is directly executed or inserted into downstream systems. OWASP's LLM guidance demonstrates that security controls must surround the model rather than rely on the model to protect itself.

F. Governance and Human Oversight

The NIST AI RMF provides a structured approach for identifying, measuring, and managing AI risks across the lifecycle. Its generative AI profile extends this approach to risks that are particularly relevant to generative systems. UNESCO's Recommendation on the Ethics of AI emphasizes human dignity, fairness, transparency, and human oversight. These approaches indicate that responsible AI is not only a technical property. It also involves organizational accountability, user communication, monitoring, and mechanisms for intervention.

III. Proposed Risk Aware Responsible Generative AI Framework

The proposed framework treats a generative AI application as a socio technical system with five layers: governance, data and knowledge, model interaction, output assurance, and monitoring. The central design principle is defense in depth. Each layer addresses different risks, and failure in one layer should not automatically lead to harmful system behavior.

The five layers map onto four operational stages. Layer 1 corresponds to pre deployment assessment. Layers 2 and 3 correspond to controlled generation. Layer 4 corresponds to post generation verification. Layer 5 corresponds to continuous monitoring.

A. Layer 1: Governance and Risk Definition

Before deployment, the system owner should define the intended use, prohibited use, user population, acceptable risk level, data sensitivity, and human escalation policy. Each use case should have a risk classification such as low, medium, or high impact. High impact applications should require stricter human review and evidence requirements.

A system card or application risk register should record the model version, data sources, known limitations, safety policies, evaluation results, and responsible owners. This creates traceability when the system changes.

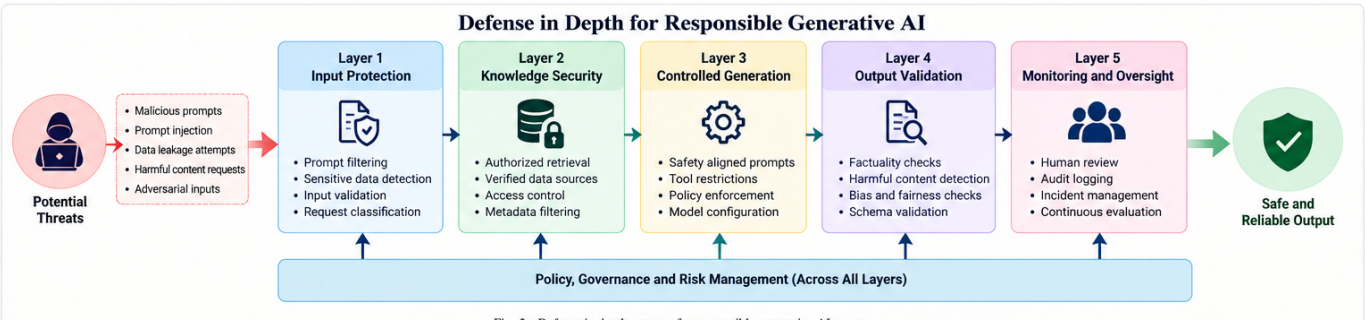


Fig. 3. Defense in depth strategy for responsible generative AI systems.

B. Layer 2: Data and Knowledge Controls

The second layer controls the information supplied to the model. Input data should be classified into public, internal, confidential, and restricted categories. Personally identifiable information should be minimized or redacted where possible.

For retrieval augmented generation systems, documents should be authenticated before indexing. Metadata should record source, owner, date, sensitivity, and version. Retrieval should enforce user authorization so that a model cannot reveal a document simply because it was retrieved by a query.

C. Layer 3: Controlled Model Interaction

The model interaction layer manages system prompts, user prompts, tool calls, and model outputs. Prompt templates should separate trusted instructions from untrusted user or retrieved content. Tool permissions should follow least privilege. A model should not receive unrestricted access to databases, file systems, or external services.

Safety policies can be expressed as explicit rules that define allowed, restricted, and prohibited behaviors. Alignment through human feedback and constitutional approaches demonstrate possible methods for aligning model behavior with a set of preferences or principles, although application level controls are still required.

D. Layer 4: Output Assurance

The output assurance layer checks whether a generated response is suitable for release. Factuality checks should compare claims against retrieved evidence where evidence is required. Sensitive information detectors can scan outputs for personal or confidential data. Safety classifiers can identify harmful or prohibited content. Structured outputs should be validated against schemas before being passed to downstream software.

For high impact decisions, the system should be able to return an uncertainty or escalation state rather than forcing an answer. This is important because responsible behavior sometimes means refusing to generate a confident response.

E. Layer 5: Human Oversight and Monitoring

Human oversight should be proportional to risk. Low risk tasks can use automated checks, while high risk tasks should require human approval before an action is executed. Users should be able to report harmful or incorrect outputs, and those reports should be connected to an incident management process.

Monitoring should track safety incidents, hallucination rates, policy violations, latency, retrieval quality, user feedback, and changes in model behavior. Evaluation should be repeated after model updates, prompt changes, retrieval index changes, or major changes in user population.

IV. Risk Assessment Methodology

The framework uses a risk score to prioritize controls. For each identified risk r, an application team estimates probability $P(r)$, impact $I(r)$, and detectability $D(r)$ on an integer scale from 1 to 5:

$$R(r) = P(r) \times I(r) \times D(r). \tag{1}$$

Detectability is scored inversely, so that a failure that is difficult to detect receives a higher value. A value of $D = 5$ means the failure is very unlikely to be noticed. A higher score $R(r)$ indicates that the risk deserves stronger preventive and detective controls.

The risk assessment process contains four stages:

1) **Identify:** enumerate risks related to the model, data, users, tools, outputs, and operational environment.
2) **Analyze:** estimate probability, impact, and detectability for each risk.
3) **Control:** assign preventive, detective, and corrective controls.
4) **Review:** repeat the assessment after significant changes.

For example, consider a customer support retrieval augmented generation system. A prompt injection that causes disclosure of internal documents may have moderate probability, high impact, and low detectability if the system has weak logging. Its priority would therefore be high. Controls would include retrieval authorization, prompt isolation, output scanning, tool restrictions, and security monitoring.

V. Conceptual Evaluation

The proposed framework was evaluated conceptually against seven responsible AI dimensions: factuality, fairness,

TABLE I
RESPONSIBLE GENERATIVE AI CONTROL MATRIX

Risk Dimension	Primary Control	Secondary Control	Evidence
Factuality	Retrieval grounding	Claim verification	Source linked response
Fairness	Bias evaluation	Human review	Group wise metrics
Privacy	Data minimization	Output scanning	Access and audit logs
Security	Prompt isolation	Least privilege	Security events
Explainability	Evidence attribution	Decision trace	Source and policy records
Robustness	Adversarial testing	Regression tests	Evaluation reports
Human Oversight	Risk based escalation	Approval workflow	Review records

privacy, security, explainability, robustness, and human oversight. The evaluation does not claim empirical performance improvement because no model specific experimental dataset was used. Instead, it examines whether each framework layer provides a direct control for each risk dimension.

The matrix shows that no single mechanism covers all dimensions. Retrieval can improve factual grounding but does not solve fairness or prompt injection. Human review can reduce the consequences of uncertain outputs but cannot compensate for poor access control. Security controls can prevent unauthorized actions but do not guarantee factuality. The framework therefore depends on layered controls.

A useful deployment metric is control coverage. Let H be the set of identified high priority risks, and let $C(r) = 1$ if risk $r \in H$ has at least one preventive control and at least one detective or corrective control, and $C(r) = 0$ otherwise. Then:

$$\text{Coverage} = \frac{1}{|H|} \sum_{r \in H} C(r). \tag{2}$$

This metric does not measure model quality directly. Instead, it measures whether the engineering team has built a sufficiently complete risk control map. It can be used as a release gate before production deployment.

VI. IMPLEMENTATION ARCHITECTURE

A practical implementation can be organized as a request pipeline following the lifecycle in Fig. **??**. The user request first passes through an input gateway. The gateway performs authentication, authorization, rate limiting, sensitive data detection, and request classification. The request is then sent to a policy engine that selects the appropriate model and safety configuration.

If external knowledge is required, a retrieval service queries an authorized knowledge store. Each retrieved document carries metadata describing its source, access level, and freshness. The orchestration layer combines trusted instructions, user input, and retrieved evidence using explicit context boundaries.

The model generates a candidate response. Before release, an output guard checks policy compliance, schema validity, sensitive information, and evidence support. For high risk actions, the response is placed into a human review queue. Approved actions are then executed through restricted tools.

Every important stage produces an audit event. The audit record should include a request identifier, model version, policy version, retrieval source identifiers, control decisions, and final outcome, while avoiding unnecessary storage of sensitive user content.

VII. DISCUSSION

The main advantage of the proposed framework is that it shifts responsible AI from a single model property to an application lifecycle practice. This is important because many failures occur outside the model. A model can be technically aligned but still become unsafe when connected to an unrestricted tool, an unauthorized database, or a poorly designed user interface.

There are also trade offs. Additional verification increases latency and infrastructure cost. Human review increases operational effort. Strict refusal policies can reduce usefulness when legitimate requests are incorrectly blocked. Retrieval grounding can improve factuality but introduces new security and data quality concerns. Therefore, responsible AI should not mean maximizing every safety control independently. Instead, controls should be selected according to the risk of the intended use.

Explainability also requires careful interpretation. For generative systems, showing a retrieved source is not equivalent to explaining why every token was generated. A practical approach is to provide evidence, policy decisions, confidence or uncertainty indicators, and an audit trail for important actions. This form of system level transparency is often more useful to users and reviewers than attempting to expose internal model reasoning.

Another important issue is change management. A responsible system can become unsafe after a model update, prompt modification, new retrieval corpus, or change in connected tools. Continuous evaluation should therefore be treated as part of software maintenance. Regression tests should include known safety cases, adversarial prompts, privacy tests, fairness tests, and domain specific factuality tests.

VIII. LIMITATIONS AND FUTURE WORK

The framework is conceptual and has not been validated through a controlled experiment on a specific LLM or production workload. The risk score in (1) is intentionally simple and depends on expert judgment. Different organizations may assign different probability and impact values to the same risk.

Future work should implement the framework in a real retrieval augmented generation application and compare baseline and controlled versions using standardized benchmarks such as HELM [8]. Evaluation should include hallucination rate, harmful output rate, prompt injection success rate, sensitive information leakage, fairness metrics, latency, and cost. Another research direction is adaptive risk control, where the system automatically increases verification and human review

when the request is classified as high impact or when evidence quality is low.

IX. Conclusion

Responsible generative AI requires more than improving model capability. A trustworthy application must control data, prompts, tools, retrieval, outputs, and operational decisions across the full lifecycle. This paper proposed a layered, risk aware framework that combines governance, data controls, constrained model interaction, output assurance, human oversight, and continuous monitoring. The conceptual evaluation shows why defense in depth is necessary: different controls address different classes of failure, and no single technique can guarantee responsible behavior.

The proposed framework provides a practical bridge between high level responsible AI principles and application engineering. By treating factuality, fairness, privacy, security, explainability, robustness, and human oversight as explicit engineering requirements, organizations can make generative AI systems more trustworthy while retaining their practical usefulness.

References

[1] L. Huang *et al.*, "A survey on hallucination in large language models: Principles, taxonomy, challenges, and open questions," arXiv:2311.05232, 2023.

[2] OWASP Foundation, "OWASP Top 10 for LLM Applications 2025," OWASP GenAI Security Project, 2024.

[3] UNESCO, "Recommendation on the Ethics of Artificial Intelligence," United Nations Educational, Scientific and Cultural Organization, Paris, France, 2021.

[4] C. Autio *et al.*, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST AI 600 1, 2024, doi: 10.6028/NIST.AI.600 1.

[5] R. Schwartz, A. Vassilev, K. Greene, L. Perine, A. Burt, and P. Hall, "Towards a standard for identifying and managing bias in artificial intelligence," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST SP 1270, 2022.

[6] L. Ouyang *et al.*, "Training language models to follow instructions with human feedback," in *Advances in Neural Information Processing Systems*, vol. 35, 2022, pp. 27730 27744.

[7] Y. Bai *et al.*, "Constitutional AI: Harmlessness from AI feedback," arXiv:2212.08073, 2022.

[8] P. Liang *et al.*, "Holistic evaluation of language models," arXiv:2211.09110, 2022.